

THE FUTURIST'S STRATEGY CONE™

A Human-Controlled Governance Framework
for Agentic AI in Internal Audit

4 STAGES: Risk → Audit → Evidence → Reporting



RISK

Identify, assess and prioritize AI risks across processes and data.



AUDIT

Design and perform intelligent audits with AI oversight and human judgment.



EVIDENCE

Capture immutable, traceable and verifiable audit evidence.



REPORTING

Deliver meaningful insights for assurance and decision-making.



Agentic AI
Audit Leader



Predictive
Intelligence



Real-time
Assurance



Stronger
Governance

ADNAN SHAMIM

AGENTIC AI LEADER

INTERNAL AUDIT & AI GOVERNANCE PROFESSIONAL



EMAIL

ad.shamim1985@gmail.com



MOBILE

03138224669



CREATOR OF
**THE FUTURIST'S
STRATEGY CONE™**



Designed for Boards, CFOs & CAEs
to Govern Agentic AI with Confidence



AI Enhances Capability,
Humans Maintain Accountability.



Explore the
Framework

Scan to
learn more.



ad.shamim1985@gmail.com



03138224669



linkedin.com/in/
adnan-shamim-802a6622b



DM **"CONE"** for Framework

HOW TO AUDIT AI GOVERNANCE

The real Internal Audit question is not: “Does the AI work?”

As AI moves from assistance to autonomy, Internal Audit needs to change the question.

Not:

- ✗ “Is the model accurate?”
- ✗ “Do we have an AI policy?”
- ✗ “Is there a human in the loop?”
- ✗ “Is the dashboard green?”

But:

“Can management demonstrate, with sufficient evidence, that AI-enabled processes are governed, operating within approved authority and risk boundaries, subject to effective controls, and appropriately monitored as circumstances change?”

That is where **AI Governance** becomes **auditable.**

1 START WITH THE BUSINESS RISK

Don't start with the model.

Start with the **business process**.

Ask:

- What is AI changing?
- What decision or activity does it influence?
- What could go wrong?
- Who could be affected?
- What is the potential impact?
- What risk is management accepting?

Then determine the appropriate audit depth.

Risk determines the depth of assurance.

A productivity assistant is not the same risk as an agent capable of executing financial, customer, compliance or operational actions.

2 ESTABLISH ACCOUNTABILITY

Map the governance chain:

Board / Senior Management



AI Governance



Risk Owner



Business / Process Owner



Technology / Model Owner



Operational User



AI System / Agent

Ask:

- Who approves?
- Who owns the risk?
- Who can change it?
- Who can stop it?
- Who monitors it?
- Who accepts residual risk?
- Who escalates material issues?

A committee meeting is not evidence of effective governance.

Audit the decisions, challenge, escalation and follow-through.

3 KNOW WHAT AI ACTUALLY EXISTS

Do not rely solely on the formal AI register.

Look for:

- Generative AI
- AI agents
- Embedded AI
- Automated decision systems
- Third-party AI
- AI connected to enterprise systems
- Employee-deployed tools
- Shadow AI

Then reconcile:

What management says exists

with

what is actually being used.

Because:

You cannot effectively govern what you cannot identify.



AUDIT PURPOSE

→ AUTHORITY → BOUNDARY

For every material AI use case, establish:

PURPOSE

Why is AI being used?

AUTHORITY

What has management authorized it to do?

BOUNDARY

What is outside that authority?

ESCALATION

When must it stop or involve a human?

REVOCATION

Who can suspend or withdraw its authority?

This becomes critical with **Agentic AI**.

An agent connected to enterprise data, systems and tools may be exercising **delegated organizational authority**.

That authority must be controlled.

A boundary is only meaningful when it is:

**Defined → Authorized → Enforced →
Monitored → Tested → Escalated**

If management cannot demonstrate where AI must stop, Internal Audit cannot credibly assess whether its autonomy is adequately controlled.

5 TEST THE BOUNDARY — DON'T JUST READ IT

Management says:

“The agent cannot approve transactions above X.”

Don't stop at the policy.

Test whether it can actually execute one.

Management says:

“Low-confidence cases are escalated.”

Test whether escalation actually occurs.

Management says:

“Restricted information cannot be accessed.”

Test the actual access path—including connected tools and APIs.

This is the difference between:

DECLARED GOVERNANCE

and

ENFORCED GOVERNANCE.

6 TEST HUMAN OVERSIGHT FOR EFFECTIVENESS

Don't ask:

"Is there a human in the loop?"

Ask:

**"Can the human
meaningfully
challenge,
intervene, override
or stop the AI
before
unacceptable
consequences
occur?"**

Test:

- Information available
- Competence
- Decision authority
- Timing
- Override capability
- Escalation
- Accountability

A person clicking “**Approve**” does not automatically constitute meaningful oversight.

Human presence ≠ human control.



TEST THE CONTROL SYSTEM

For each material risk:

Risk → Control Objective → Control → Owner → Evidence → Test → Result → Outcome

Assess:

DESIGN

Is the control appropriately designed for the risk?

IMPLEMENTATION

Has it actually been implemented?

OPERATING EFFECTIVENESS

Did it operate as intended?

OUTCOME

Did it achieve its intended risk-management purpose?

Because:

A control can exist.

A control can operate.

And the underlying risk can still remain inadequately controlled.

That is why AI governance auditing cannot become a checklist exercise.

AUDIT CHANGE — NOT JUST THE INITIAL STATE

AI governance cannot be treated as a one-time deployment exercise.

Ask:

- What changed?
- Who changed it?
- Why?
- Was the change authorized?
- Was risk reassessed?
- Was testing performed?
- Did the decision boundary change?
- Did data, tools, APIs or access change?
- Did the underlying AI service change?

Then ask the harder question:

“How does management know the controls still work after the change?”

A successful test yesterday does not automatically provide assurance for tomorrow.

This is where AI changes the assurance equation.

Internal Audit needs to be **forward-looking**, focusing on risks created by changing technologies and business processes—not simply continuing to audit yesterday's processes.



AUDIT THE EVIDENCE CHAIN

For material or higher-risk AI activity, determine whether sufficient evidence exists to support independent assurance.

Depending on the risk, this may include:

Identity

- **Input / Data**
- **Applicable Policy**
- **Control / Policy Version**
- **Model / Agent Version**
- **Decision / Action**
- **Exception / Threshold**
- **Human Intervention**
- **Outcome**

The objective is **not** unlimited logging.

The objective is:

**Sufficient, relevant
and reliable
evidence to support
accountability,
investigation and
assurance.**

Ask:

**“If this decision is challenged six
months from now, can
management reconstruct what
happened and explain why?”**

That is practical **AI** auditability.

10 AUDIT THIRD-PARTY AI

A vendor providing AI does not automatically transfer the organization's responsibility for how that AI is used.

Test:

- Vendor due diligence
- Contractual accountability
- Data use
- Security
- Service changes
- Subcontractors
- Resilience
- Incident notification
- Continuity
- Exit arrangements
- Relevant assurance

And ask:

“What change at the vendor could materially change our risk—and how would management know?”

AUDIT FAILURE CONDITIONS

Don't test only normal operation.

Test what happens when:

- AI exceeds its authority
- A control fails
- Data quality deteriorates
- Performance changes materially
- A prohibited action is attempted
- A connected system fails
- A third-party service changes
- A material incident occurs

Can management:

**Detect → Contain → Stop → Escalate →
Investigate → Recover → Learn?**

A circuit breaker that has never been tested is an assumption.

Not assurance.

1 2 TEST THE BUSINESS OUTCOME

This is where technical AI testing can become misleading.

A model can perform well technically while the **business control environment still fails**.

Therefore examine:

- Exceptions
- Overrides
- Complaints
- Losses
- False positives / negatives
- Regulatory breaches
- Near misses
- Control failures
- Unintended consequences

The question is not:

“Is the AI perfect?”

It is:

**“Are governance,
risk management
and controls
achieving their
intended purpose?”**

THE AUDIT COMMITTEE QUESTION

If I had to reduce an **AI Governance
Audit** to one question:

“How does management know that AI remains within its approved purpose, authority and risk boundaries—and that the controls continue to work as the environment changes?”

That connects:

Governance

- **Risk**
- **Authority**
- **Boundary**
- **Controls**
- **Change**
- **Evidence**
- **Outcomes**
- **Accountability**

THE THIRD-LINE BOUNDARY

Internal Audit should:

Assess.
Challenge.
Test.
Conclude.
Report.

Management should:

Own the risk.
Design the controls.
Operate the controls.
Monitor the controls.
Remediate weaknesses.

Internal Audit should not become
management's **AI control owner**.

Its role is to provide independent,
objective assurance and challenge—not
to own management's AI risks or
controls.

THE AI-ERA ASSURANCE QUESTION

Traditional audit asks:

“Did the control work?”

AI-era assurance must also ask:

“What evidence supports that the control remains effective as the AI, process, data and operating environment change?”

That does **not** mean auditing everything continuously.

It means applying **risk-based continuing assurance** where the AI's autonomy, impact, volatility or rate of change warrants it.

That is a **forward-looking Internal Audit model**, not a static compliance review.

WHAT GOOD AI GOVERNANCE SHOULD BE ABLE TO DEMONSTRATE

PURPOSE

Why is AI being used?

AUTHORITY

What is it permitted to do?

BOUNDARY

Where must it stop?

CONTROL

What prevents, detects and responds to unacceptable outcomes?

OVERSIGHT

Who can meaningfully intervene?

EVIDENCE

How do we know?

OUTCOME

Did the controls achieve their intended purpose?

ACCOUNTABILITY

Who remains responsible?

CHANGE

How do we know governance remains effective?

THE BOTTOM LINE

AI Governance is not effective merely because:

- ✗ A policy exists
- ✗ A committee meets
- ✗ A model has high accuracy
- ✗ A dashboard is green
- ✗ A human is “in the loop”
- ✗ A vendor provides assurance

It becomes **auditable** when management can demonstrate:

CLEAR PURPOSE

DEFINED AUTHORITY

ENFORCEABLE BOUNDARIES

EFFECTIVE CONTROLS

MEANINGFUL OVERSIGHT

SUFFICIENT EVIDENCE

ACCOUNTABLE OWNERSHIP

**RESPONSIVE CHANGE
MANAGEMENT**

And Internal Audit can independently assess whether those arrangements are appropriately designed, implemented and operating effectively for the risks being addressed.

THE PRINCIPLE

**AI OPERATES WITHIN
AUTHORIZED PURPOSE AND
BOUNDARIES.**

MANAGEMENT OWNS THE RISK.

**CONTROLS CONSTRAIN AND
MONITOR AI.**

**EVIDENCE ENABLES
ASSURANCE.**

**INTERNAL AUDIT
INDEPENDENTLY CHALLENGES.**

And the question that matters most:

**“CAN
MANAGEMENT
DEMONSTRATE
THAT AI REMAINS
CONTROLLED AS IT
CHANGES?”**

That is the shift:

**FROM AUDITING AI
TO AUDITING THE
GOVERNANCE AND
CONTROL SYSTEM THAT
ENABLES AI TO OPERATE.**

AI Governance is not a policy document.

It is an operating control system.

And if it cannot produce evidence—

it cannot produce credible assurance.

THE FUTURIST'S STRATEGY CONE™

Reimagining Internal Audit for the Age of Agentic AI



By **Adnan Shamim**